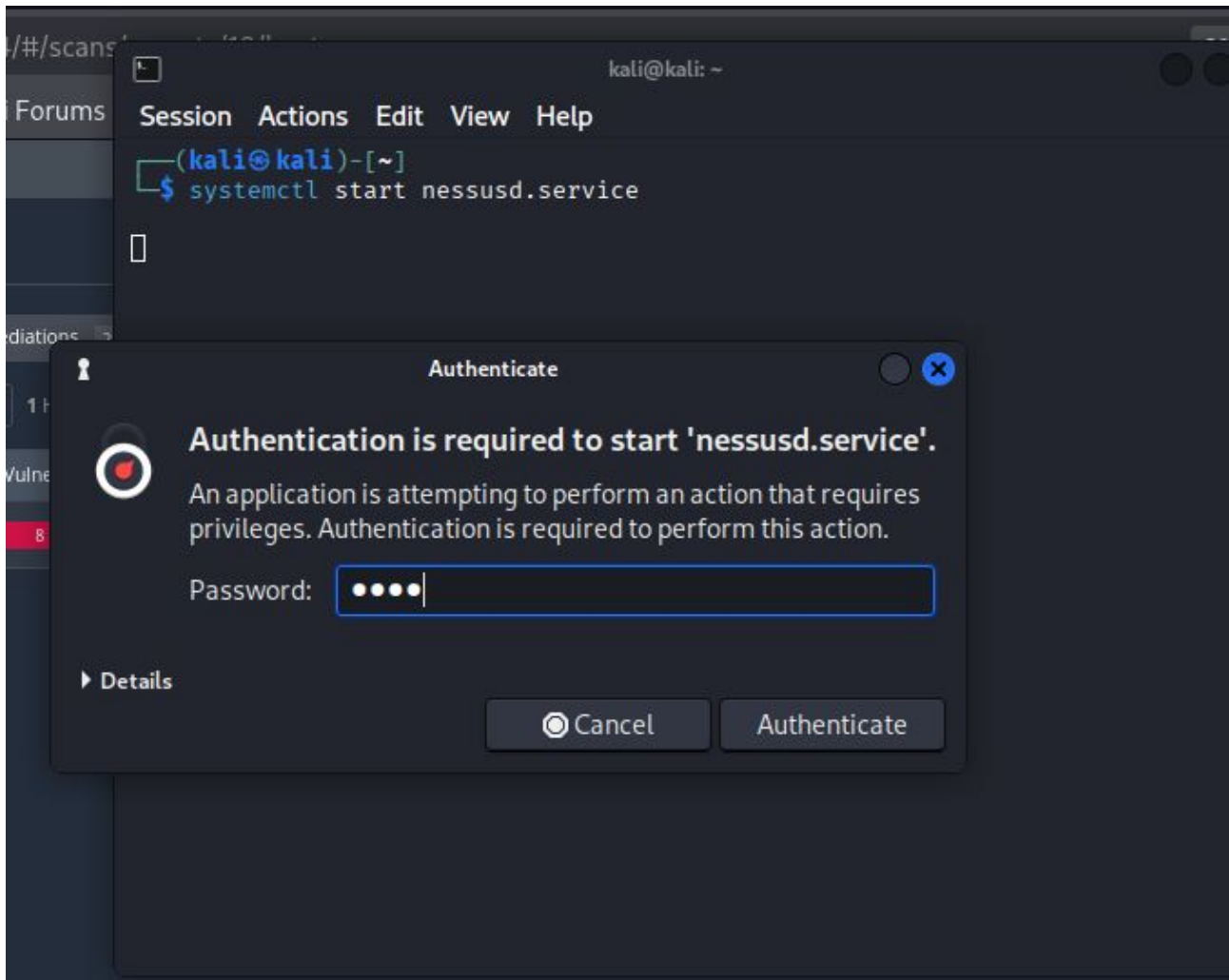


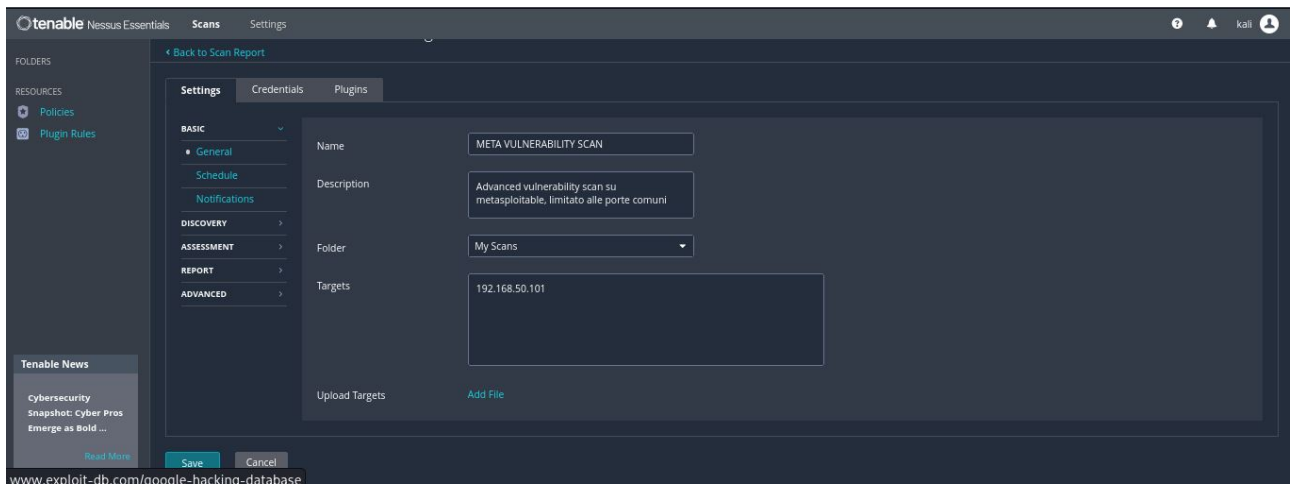
ESERCIZIO VULNERABILITY SCANNING

Per effettuare un Vulnerability Scanning come prime cosa, dalla Metasploitable sono risalito subito all'IP della macchina: 192.168.50.101 per la configurazione successiva e verificato tramite ping che la Kali e la Meta comunicassero.

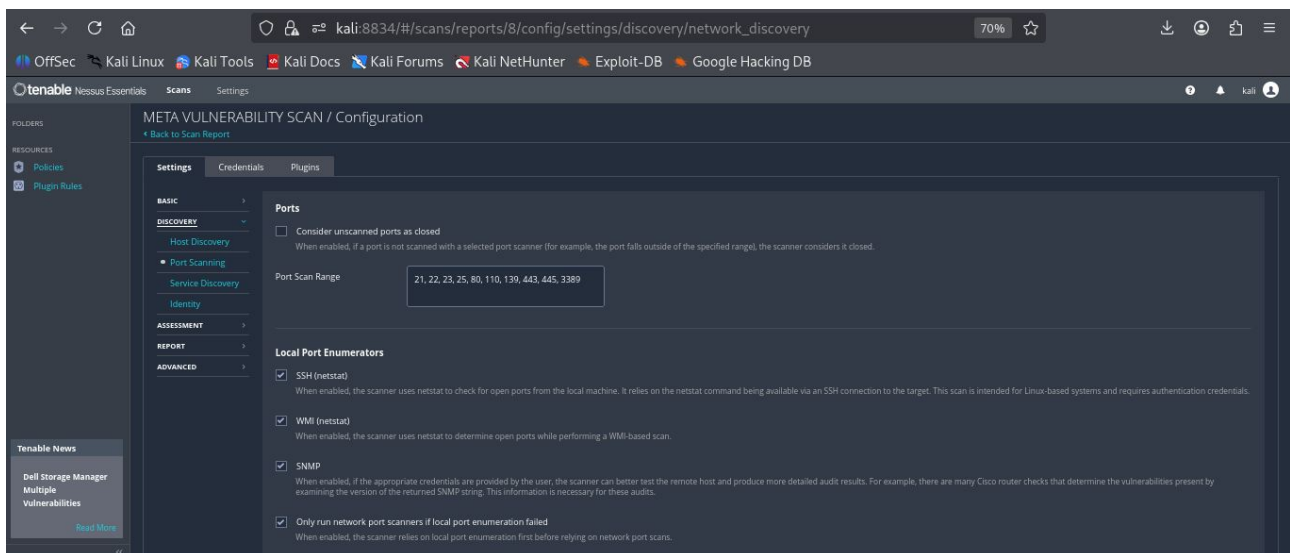
Per effettuare un Vulnerability Scanning ho eseguito il comando sulla Kali per avviare il servizio nessusd



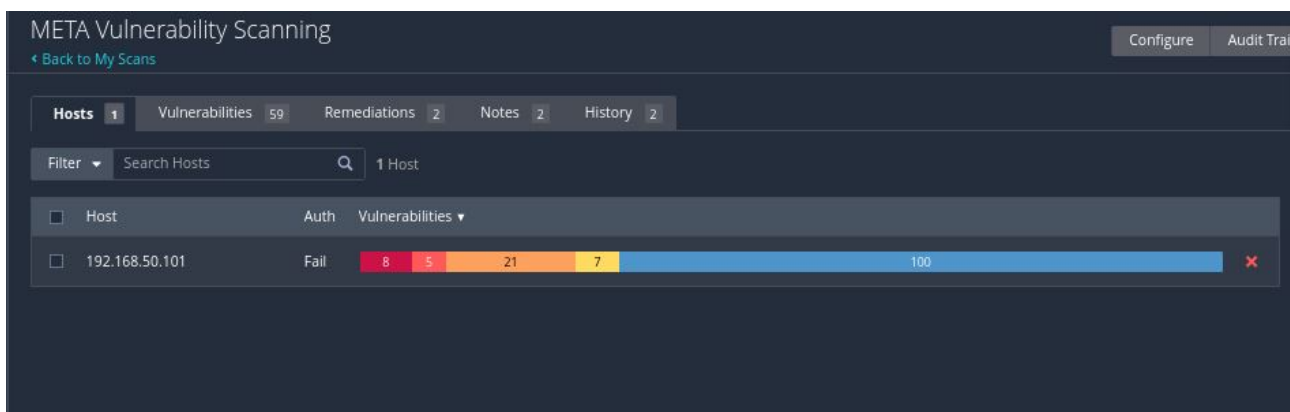
Su Nessus essentials dove aver creato una nuovo scanner, ho iniziato a compilare la maschera setting nel sotto menù basic/general



Subito dopo ho configurato le porte 21, 22, 23, 25, 80, 110, 139, 443, 445, 3389 nella maschera DISCOVERY sotto menù port scanning ed ho salvato i settaggi.



HO LANCIATO LA SCANSIONE dove alla fine della ricerca sono state rilevate 59 vulnerabilità



Ne verifico 3 una critica, una media ed una info:

Critical

Apache Tomcat AJP Connector Request Injection (Ghostcat)

CRITICAL Apache Tomcat AJP Connector Request Injection (Ghostcat) < >

Description

A file read/inclusion vulnerability was found in AJP connector. A remote, unauthenticated attacker could exploit this vulnerability to read web application files from a vulnerable server. In instances where the vulnerable server allows file uploads, an attacker could upload malicious JavaServer Pages (JSP) code within a variety of file types and gain remote code execution (RCE).

Solution

Update the AJP configuration to require authorization and/or upgrade the Tomcat server to 7.0.100, 8.5.51, 9.0.31 or later.

See Also

<http://www.nessus.org/u78ebe6246>
<http://www.nessus.org/u74e287adb>
<http://www.nessus.org/u7cb3d54e>
<https://access.redhat.com/security/cve/CVE-2020-1745>
<https://access.redhat.com/solutions/4851251>
<http://www.nessus.org/u7dd218234>
<http://www.nessus.org/u7d772531>
<http://www.nessus.org/u72a01d6bf>
<http://www.nessus.org/u73b5af27e>
<http://www.nessus.org/u79dab109f>
<http://www.nessus.org/u75eafcf70>

Descrizione

Nessus ha trovato un difetto di sicurezza molto grave in Apache Tomcat, un software che fa girare i siti web. Questo difetto riguarda una parte chiamata AJP che non deve essere accessibile dall'esterno, ma in questo sistema lo è.

Se qualcuno trova questo server in rete può: leggere file interni del sito, rubare informazioni e in alcuni casi eseguire comandi sul server. (entrare nel server senza password)

Soluzioni:

- Aggiornare Tomcat ad una versione più nuova
- Disattivare AJP se non serve
- Proteggere AJP con password o firewall

Medium HTTP TRACE / TRACK Methods Allowed

META Vulnerability Scanning / Plugin #11213 Configure Audit Trail

[← Back to Vulnerability Group](#)

Hosts 1 **Vulnerabilities 59** Remediations 2 Notes 2 History 2

MEDIUM HTTP TRACE / TRACK Methods Allowed >

Description

The remote web server supports the TRACE and/or TRACK methods. TRACE and TRACK are HTTP methods that are used to debug web server connections.

Solution

Disable these HTTP methods. Refer to the plugin output for more information.

See Also

<http://www.nessus.org/u7e979b5cb>
<http://www.apacheweek.com/issues/03-01-24>
<https://download.oracle.com/sunalerts/1000718.1.html>

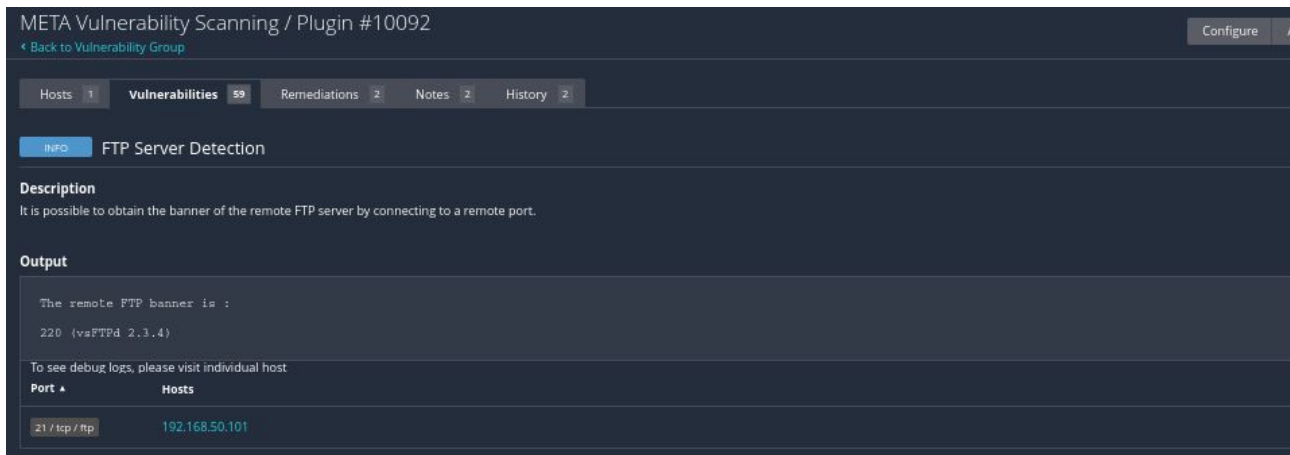
Output

Descrizione

In questo caso nessus ha rilevato che il server web consente i metodi HTTP TRACE e TRACK. Tali metodi non sono necessari e possono essere sfruttati per intercettare informazioni sensibili come cookie di sessione.

Soluzione: Disabilitare i metodi HTTP nella configurazione del server web.

Info FTP Server Detection



Descrizione:

Nessus ha rilevato la presenza di un servizio FTP attivo che espone il banner contenente il software e la versione utilizzata. Tale vulnerabilità fornisce dettagli utili a un potenziale attaccante per individuare exploit noti associati alla versione del servizio.

Soluzione:

Si consiglia disabilitare il servizio se non necessario, o di limitare l'esposizione delle informazioni o utilizzare protocolli sicuri come SFTP.

NOTA CONCLUSIVA:

La scansione di vulnerabilità con Nessus su Metasploitable ha permesso di individuare numerose criticità, confermando l'insicurezza del sistema. Sono emerse diverse vulnerabilità legate a servizi esposti, configurazioni deboli e software obsoleto. L'analisi consente di comprendere il reale impatto di ogni vulnerabilità con le successive indicazioni per ridurre gli eventuali attacchi.

L'esercizio dimostra l'importanza della scansione della vulnerabilità per valutare la sicurezza di un sistema.